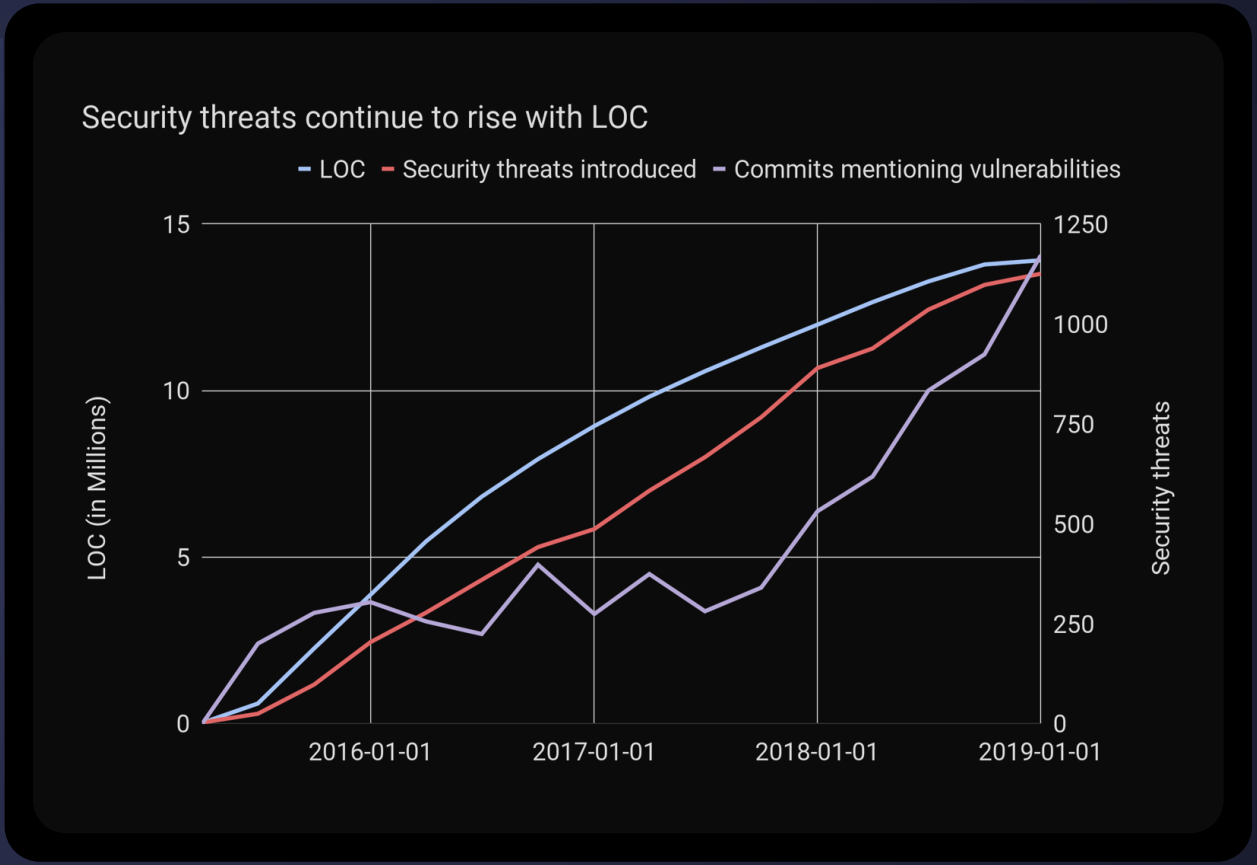
GitHub Advanced Security

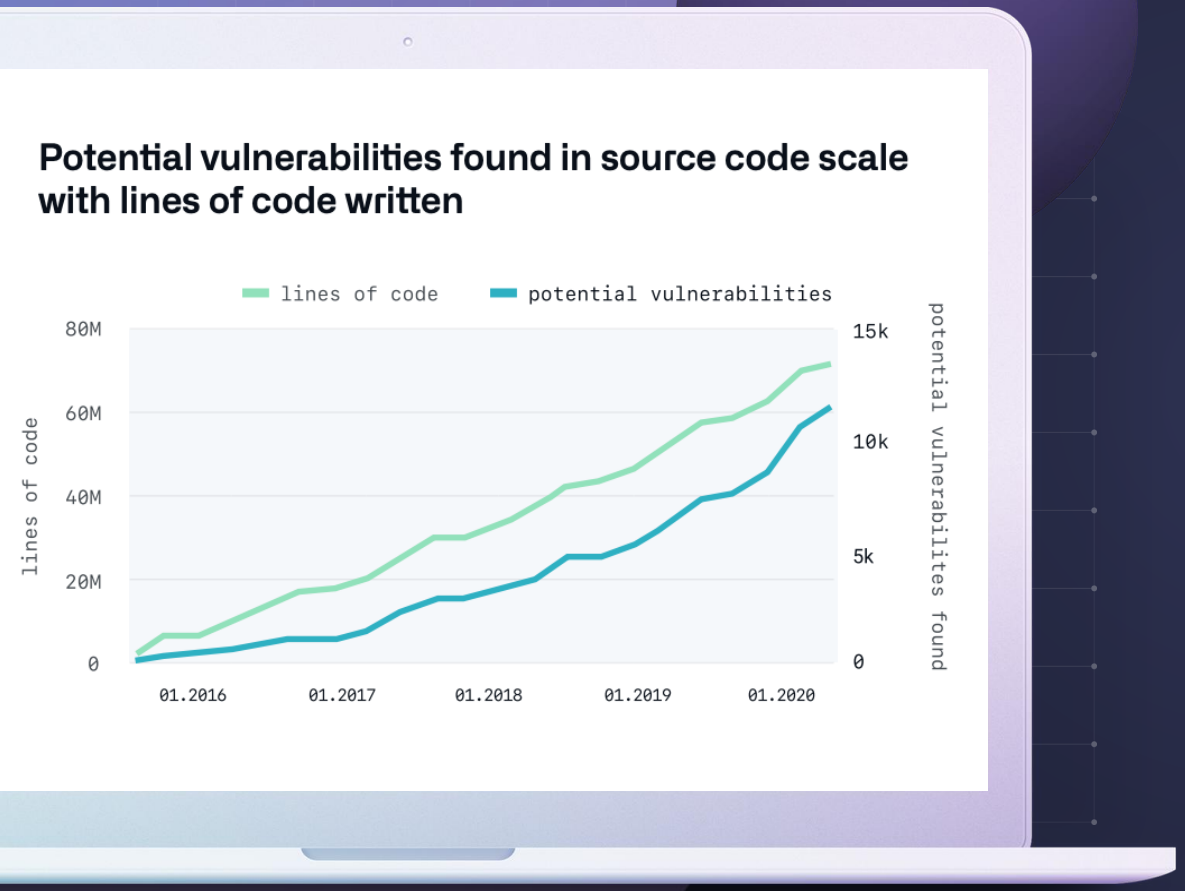
Saba Jamalian
Senior Software Solution Engineer

Despite increasing developer awareness, security threats continue to rise



The state of AppSec

Despite billions of dollars of investment…



- 85% of applications still contain a security issue
- Code written in 2020 is just as likely to introduce a security issue as code written in 2016

The state of AppSec

is falling further behind the current state of Development

- 1:100 Security team members to developers
- Lack of knowledge voted the main AppSec challenge
- Remediation trends are stagnant

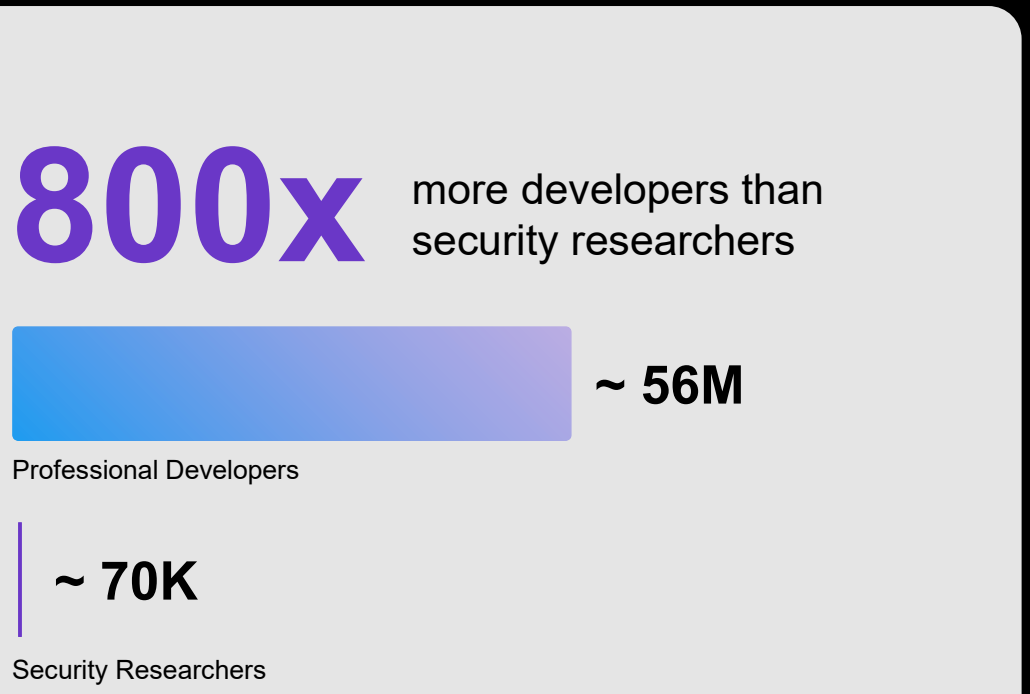
Flaws in applications are consistently the #1 attack vector for breaches

Source: Verizon Data Breach Investigations reports 2016, 2017, 2018, 2019 and 2020.

Everyone wants to shift security left…

Sources: NIST, Ponemon Institute

Solution:
Shift security left, but how?



The GitHub Difference

Developer empowered security to fix in minutes not months

Native

Embedded from in it to ship

Automatically deployed

Detailed changelog

Visibility into security posture across all code

Trust-By-Design

Static code analysis

Supply chain analysis

Secret scanning

Security Lab

Extensible platform

Fix in minutes

In-context feedback

Automated fixes

Jargon free language

Blameless culture

Community Driven

Supported by millions of developers and security researchers

Contributions from leading peers

Native Application Security

Secure code without disrupting innovation with security testing embedded in the developer experience

> Security at the expense of usability comes at the expense of security.
>
> **Lee Cookson**
> Engineering Director | @ Dow Jones

- **Embedded from init to ship**
- **Automatically deployed** to immediately increase code coverage
- **Detailed changelog** demystifying progress and simplifying audit/collaboration
- **Security overview** provides visibility into security posture across all code

Trust-by-design

> GitHub helps us ensure that we have our security controls baked into our pipelines all the way from the first line of code you're writing.

Miguel El Lakkis
Chief Information Security Officer | @ Dow Jones

Trust your software with an end-to-end security solution for securing your software supply chain and code, that developers actually use and love!

- Static code and supply chain analysis
- Secret detection and leak prevention
- Extensible platform with SARIF support

Fix in minutes

> Our engineering teams place tremendous value in GitHub's latest security features like vulnerability alerts and automated fixes.
>
> **Jon Parise**
> Engineering Architect | @ Pinterest

Empower developers with more accurate results and fix the vulnerabilities that matter the most for your organization

- **In-context feedback and automated fixes** where possible leading to industry leading fix rates and MTTR
- **Jargon free language** that empowers developers to fix without security intervention
- **Blameless developer trusted culture** that leads to higher adoption of fixes

Community driven

Benefit from thousands of analyses created by GitHub's team of security researchers and language experts and contributions from other GitHub users- such as leading security researchers at Microsoft, Google, Uber, and others.

Scale your security team with the World's Leading Security Researchers

Scale your security team with a **dedicated security team that also leverages the world's expert community of developers**

Open source foundations **encourage collaboration and community engagement**

Benefit from user driven design and frequent innovation

Innovate with Peace of Mind

Deliver secure software faster

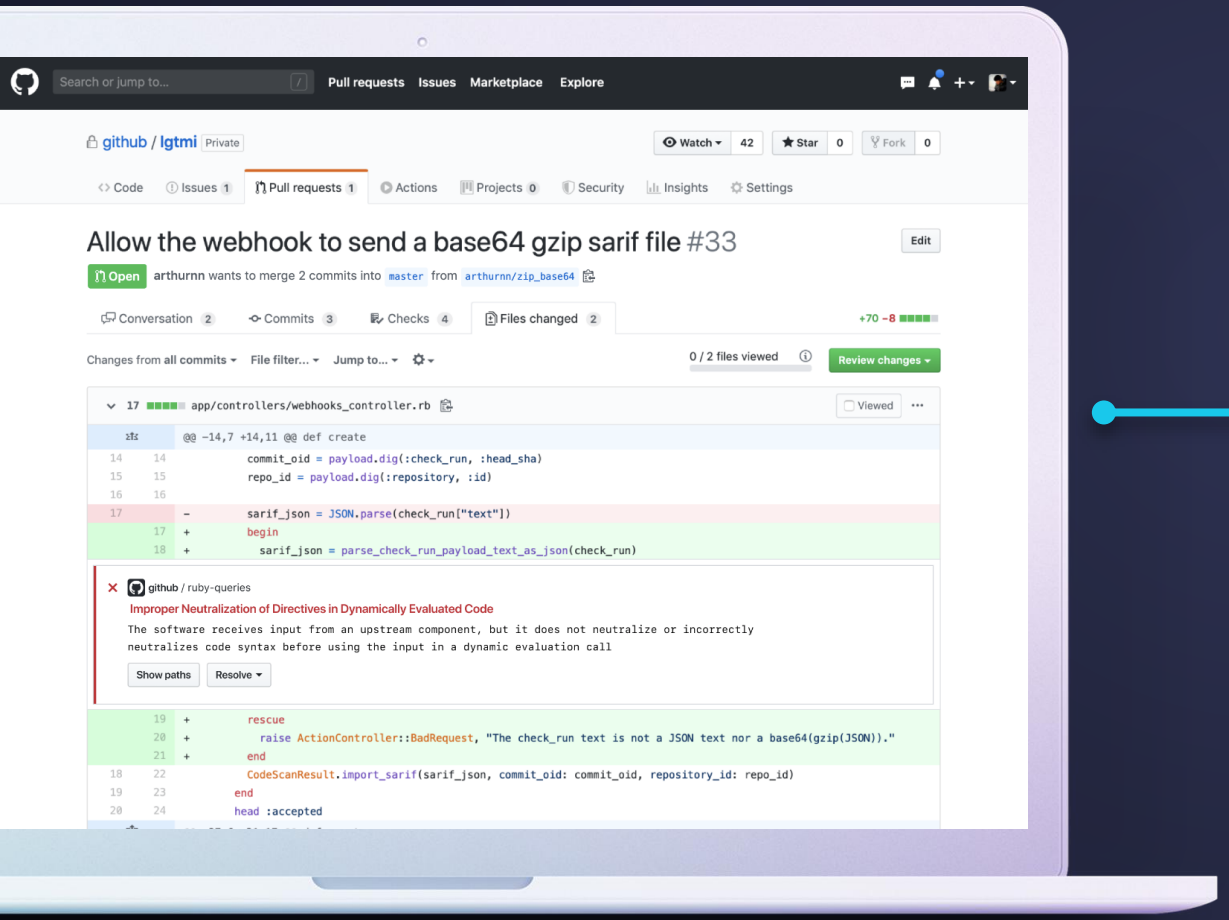
Empowered collaborative teams

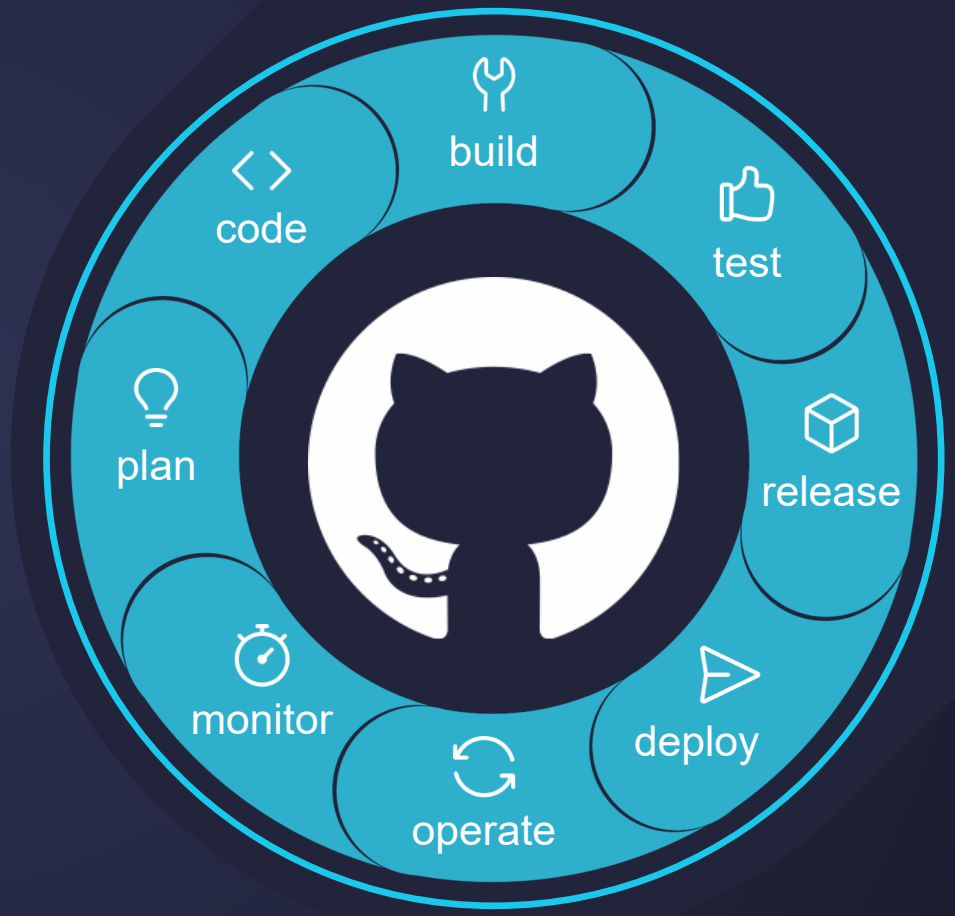
Improve security posture continuously

Secure by design

Secure development end to end

Security built into the Developer Lifecycle





Community-powered security and compliance

Dependency insights

Real-time inventory

License compliance

Vulnerability alerting

Vulnerability Management

Automated code scanning

Private secret scanning

Largest vulnerability database

Automated security updates

CodeQL

World's most advanced code analysis

Vulnerability hunting tool

Community of top security experts

GitHub Advanced Security Impact

Code vulnerability fix rate of

72%

compared to

15%

Industry norm after 7 days

OSS vulnerabilities MTTR decreased from 180 days to 40 days with Dependabot

GHAS scan and alerts for secrets and tokens from 60+ providers and growing

Dependabot

Automatically update vulnerable and out-of-date dependencies

Automated pull requests for security & version updates

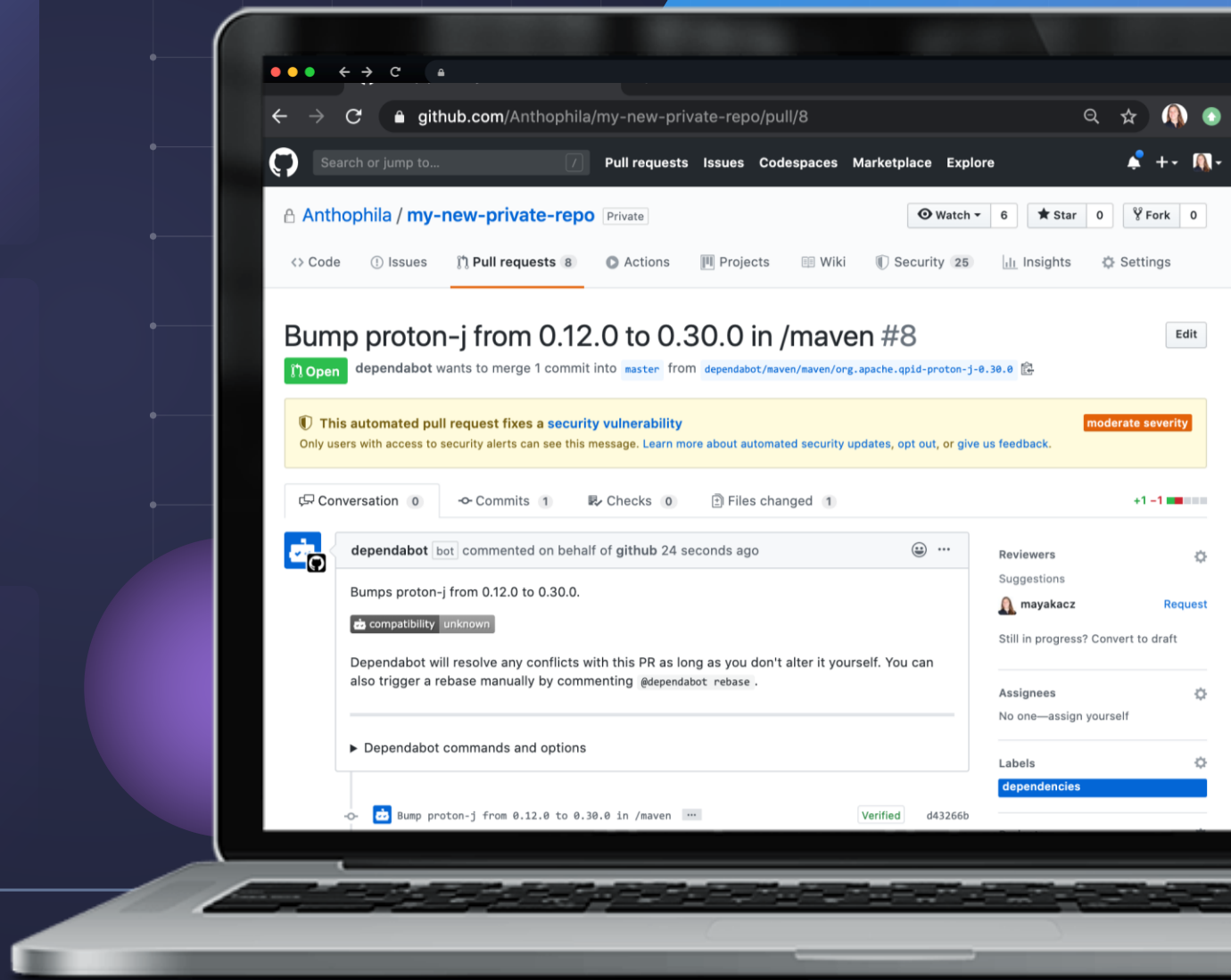
Keep your projects secure and up to date by monitoring them for vulnerable and out-of-date components. If a suggested update is found, we'll automatically open a pull request with suggested fixes.

Integrated with developer workflow

Dependabot is integrated directly into the developer workflow for a frictionless experience and faster fixes.

Rich vulnerability data

GitHub tracks vulnerabilities in packages from supported package managers using data from security researchers, maintainers, and the National Vulnerability Database—all discoverable in the GitHub Advisory Database.



Code scanning

Find and fix vulnerabilities as you code

Find and fix vulnerabilities fast

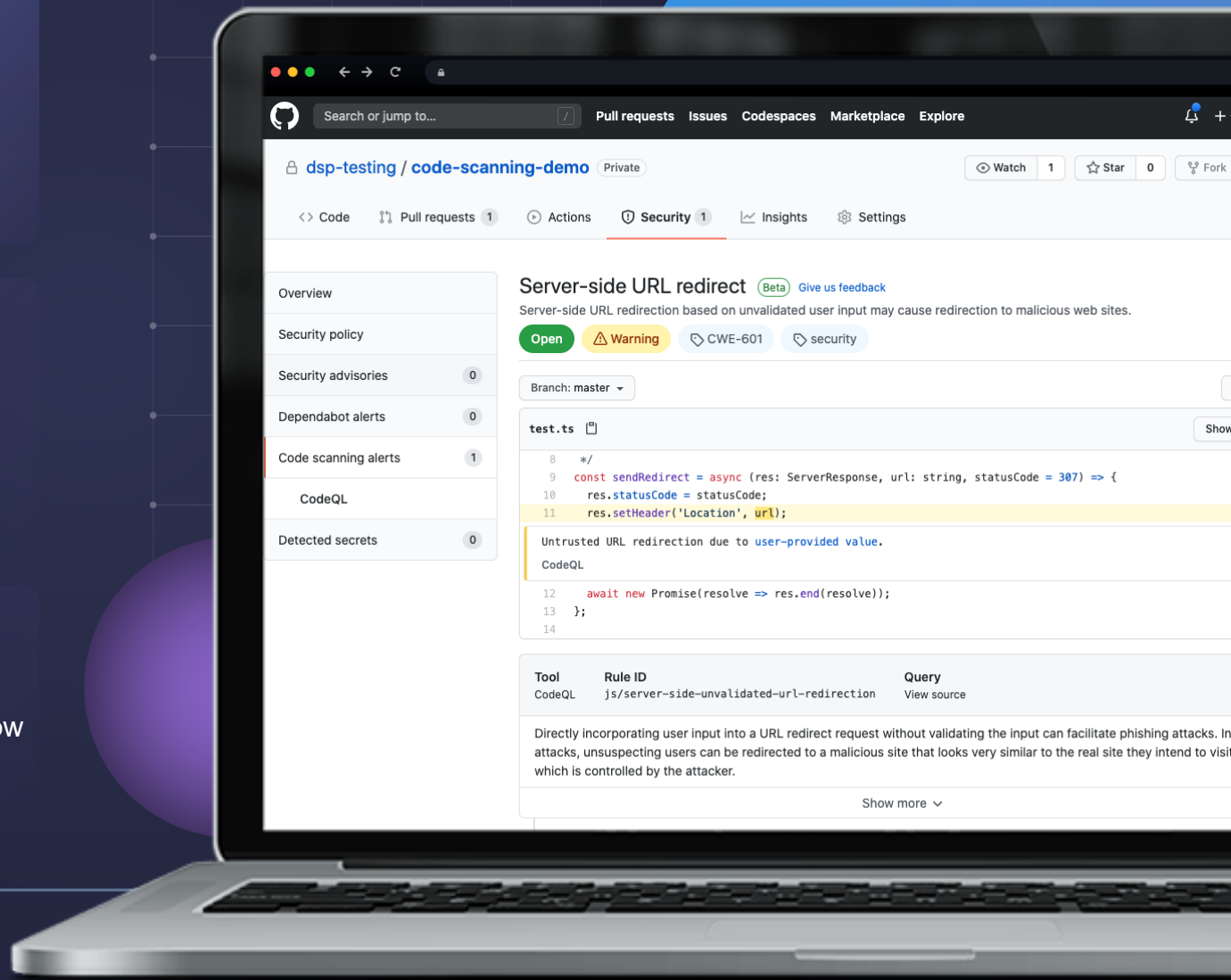
Find and fix vulnerabilities before they are merged into the code base with automated CodeQL scans.

Community of top security experts

Your projects are powered by world-class security teams. Use queries created by the security community in your projects.

Integrated with developer workflow

Integrate security results directly into the developer workflow for a frictionless experience and faster development



Secret scanning

Find and manage hard-coded secrets

Identifies secrets as early as possible

Finds secrets (including Azure secrets) the moment they are pushed to GitHub and immediately notifies developers when they are found.

Community of secret scanning partners

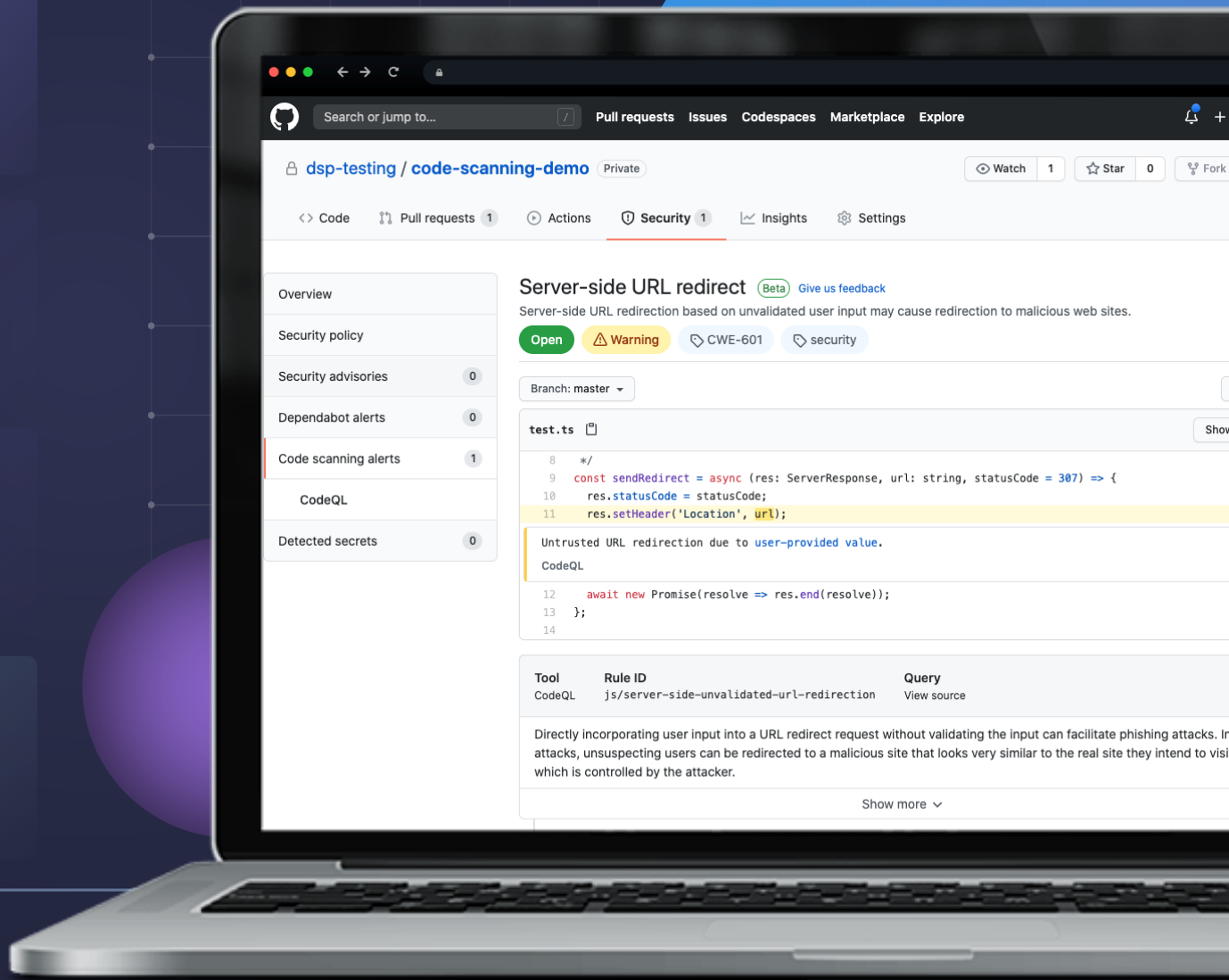
For every commit made to your repository and its full git history, we'll look for secret formats from secret scanning partners.

Define custom patterns

Scan for patterns that are internal to your organization across your repositories.

Supports both public and private repos

Secret scanning watches both public and private repos for potential secret vulnerabilities.



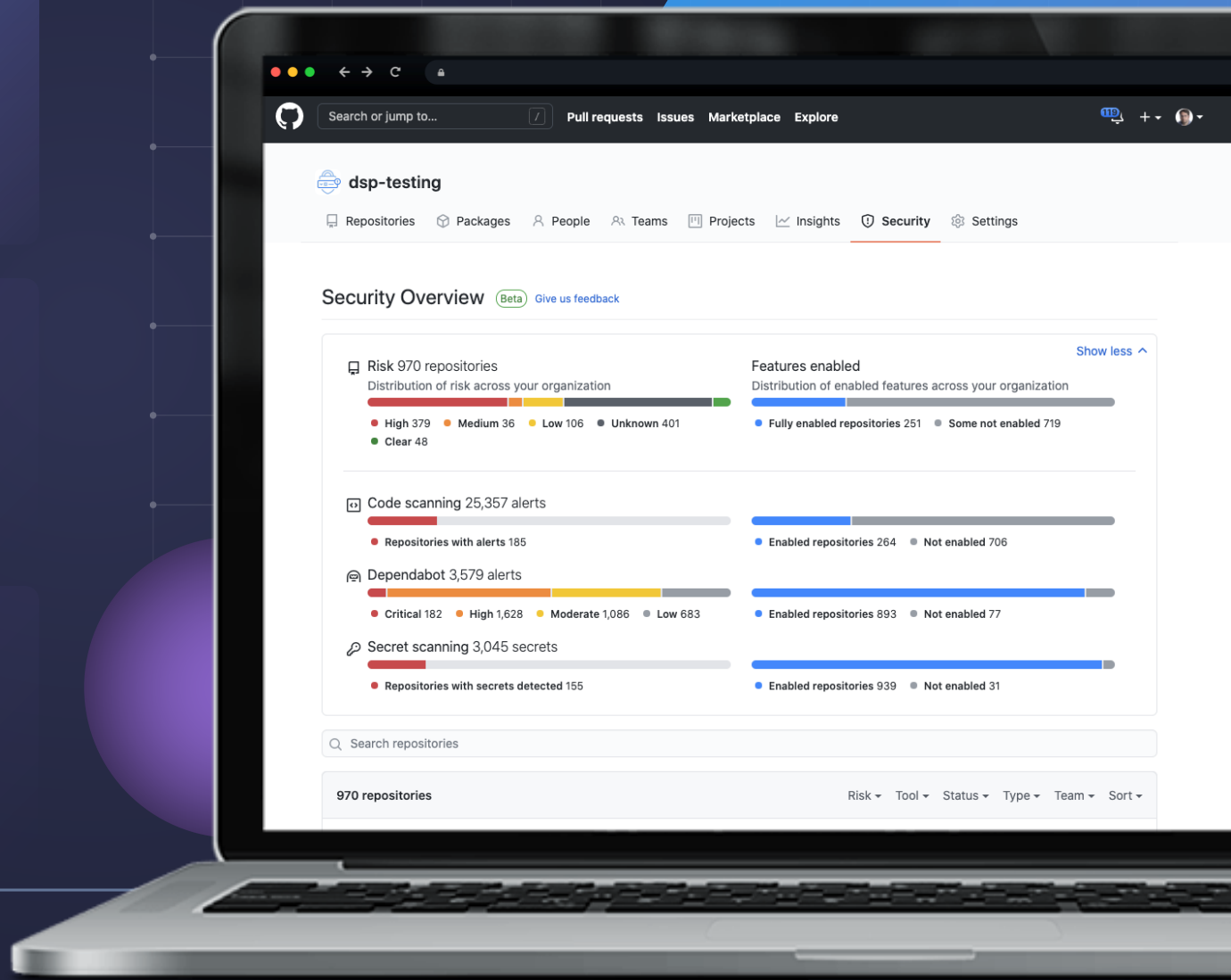
Security Overview

GA

A single place to view code scanning, secret scanning and Dependabot alerts across your codebases

Determine the riskiest repos with high numbers of unaddressed alerts

Monitor enrollment status as you rollout security features across your organization



Thank You